Created By	Makwana Naitik
Enrollment No	241105060076
Subject	Cryptography and Network Security
Branch	Diploma IT
Semester	5
Faculty	Prof. Tarjanee M. Vyas
Institution	Gyanmanjari Innovative University

ALA – 3

AIM:- Cyber Deception Chronicles

This report looks at five real cyber attacks. In each one, the attackers did not break in with advanced hacking tools. They tricked a person: through a phishing email, a fake invoice, a phone call or repeated login requests. For every case the report explains what happened, what the history of the attack was, how much loss it caused, how the company recovered, and what could have been done to stop it.

The cases are different in size and type, so the loss figures in this report are not exactly comparable. For example, Target's figure is the total cost reported by the company, while MGM's figure is the estimated effect on its earnings for one month.

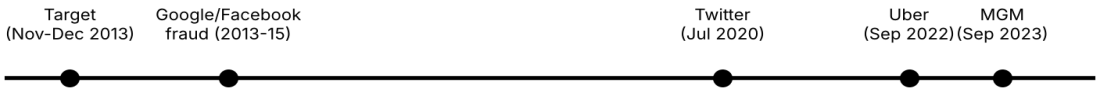


Figure 1: Timeline of the five cases

- **Summary of the five cases :-**

Case	Year	Attack type	Reported loss
Target	2013	Phishing of a vendor, stolen login	$292 million total cost reported by Target
Google and Facebook	2013-2015	Fake invoices (business email fraud)	About $121 million paid, mostly recovered
Twitter	2020	Phone phishing of employees	Over $100,000 in Bitcoin scam; major reputation damage
Uber	2022	MFA fatigue and fake IT support	No public figure; internal systems disrupted
MGM Resorts	2023	Help-desk phone call, then ransomware	About $100 million impact on earnings

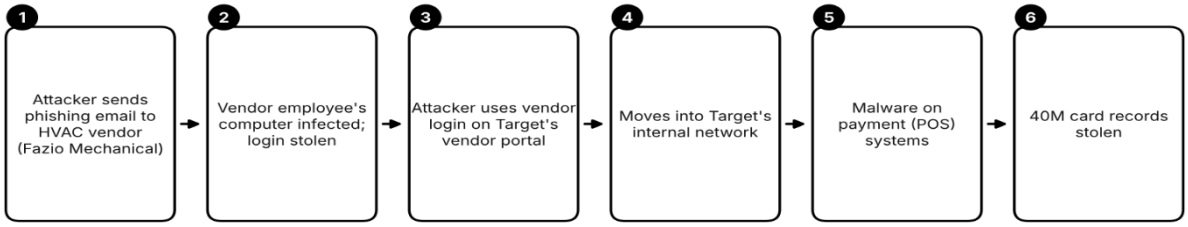
Case 1: Target corporation (2013)

❖ Overview

Company	Target Corporation, a large US retailer
When	Access gained around 15 November 2013; cards stolen between 27 November and 15 December 2013; announced 19 December 2013
Attack type	Phishing of a third-party vendor, then use of stolen vendor credentials

❖ History :-

The attackers did not go to Target directly. They first targeted Fazio Mechanical Services, a heating and air-conditioning contractor that worked with Target. Reports say a phishing email carrying malware reached the vendor, which let the attackers steal the vendor's network login. That login gave access to a Target web portal, and from there the attackers moved into Target's network and installed malware on the payment systems.





The breach happened during the busy holiday shopping season. It was first reported publicly by the security journalist Brian Krebs on 18 December 2013, and Target confirmed it the next day.

❖ **Loss :-**

- About 40 million credit and debit card records were stolen.
- Personal details (names, addresses, phone numbers or email addresses) of up to 70 million customers were also exposed.
- Target's 2016 annual report put the total cost of the breach at $292 million. After insurance, the net loss was reported as $202 million.
- Target agreed to an $18.5 million settlement with 47 state governments.
- The CEO, Gregg Steinhafel, resigned in May 2014, and the CIO had also resigned earlier that year.

❖ **Recovery process :-**

Target confirmed the breach, worked with the US Secret Service on the investigation, and offered affected customers support. The company changed its senior technology leadership and announced that it would rebuild its security approach. Legal settlements with banks, card companies and states continued for several years after the attack.

❖ **Solution:-**

- Keep vendor access separate from the payment network (network segmentation).
- Use multi-factor authentication and least privilege for vendor accounts.
- Set minimum security requirements for suppliers and check them regularly.
- Act quickly on malware alerts, so that early warnings are not ignored.

Case 2: Google and Facebook (2013-2015)

❖ Overview :-

Companies	Google and Facebook
When	October 2013 to October 2015
Attacker	Evaldas Rimasauskas, a Lithuanian man, arrested in March 2017 and extradited to the US in August 2017
Attack type	Fake invoices sent by email (a form of phishing and business email fraud)

❖ History :-

Both companies did regular business with Quanta Computer, a real company based in Taiwan. Rimasauskas set up a company with the same name in Latvia and sent emails to employees of Google and Facebook. The emails contained invoices, contracts and letters with forged signatures and even fake company stamps. The invoices looked like normal bills for goods the companies usually bought, so the accounts staff paid them into bank accounts he controlled. He then moved the money through accounts in Latvia, Cyprus, Slovakia, Lithuania, Hungary and Hong Kong.





❖ **Loss :-**

- About $23 million was taken from Google and about $98 million from Facebook, a little over $100 million in total.
- The fraud ran for two years before it was discovered.

❖ **Recovery process :-**

After the fraud was found, the companies reported it to the authorities. Google said it recovered the full amount, and Facebook said it recovered most of its money. Rimasauskas pleaded guilty to wire fraud in 2019 and agreed to forfeit $49.7 million.

❖ **Solution :-**

- Confirm any new or changed bank details by calling a known contact at the supplier, not the number on the invoice.
- Require two approvals for large payments.
- Match every invoice with a purchase order or contract before paying.
- Keep a verified list of vendors and their bank accounts.

Case 3: Twitter (2020)

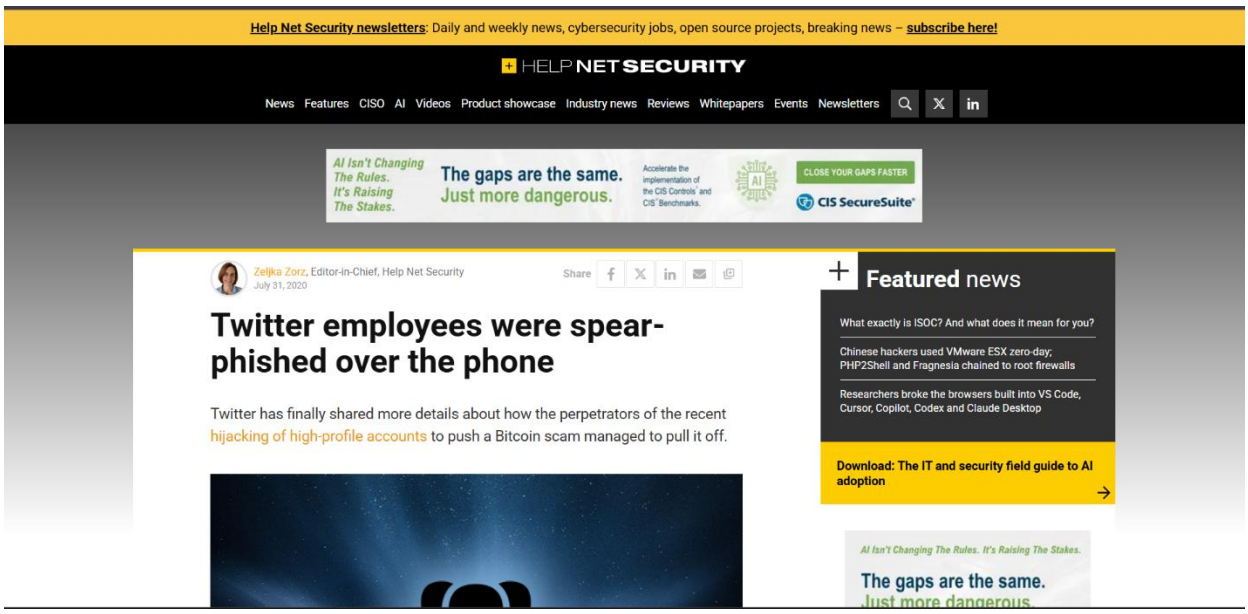
❖ Overview

Company	Twitter (now X)
When	15 July 2020
Attackers	A small group of young attackers; the main person charged was a 17-year-old from Florida, Graham Ivan Clark
Attack type	Phone spear phishing of Twitter employees

❖ History :-

Twitter said that a small number of its employees were targeted by a phone spear phishing attack. The attackers pretended to be colleagues and got employees to share their login details. This gave them access to Twitter's internal account support tools. Using these tools, the attackers targeted 130 accounts. They posted from 45 accounts, read the private messages of 36 accounts and downloaded the data of 7 accounts. The accounts posted a message asking people to send Bitcoin and promising to send back double the amount. Famous people and companies such as Barack Obama, Elon Musk, Bill Gates, Joe Biden and Apple were among the accounts used.





❖ **Loss :-**

- The Bitcoin scam collected a little over $100,000 from people around the world.
- The bigger loss was trust. Verified accounts of world leaders and companies were taken over for hours, and Twitter had to stop verified accounts from tweeting for a short time.

❖ **Recovery process :-**

Twitter blocked the affected accounts, stopped verified accounts from tweeting for a while, and limited access to its internal tools. It published an investigation update on 30 July 2020. Law enforcement arrested the main suspect in Florida within about two weeks. In March 2021 Graham Ivan Clark was sentenced to three years in prison under a plea deal.

❖ **Solution :-**

- Use hardware security keys, which are much harder to phish than passwords and SMS codes.
- Require a second person to approve actions on high-profile accounts.
- Limit how many employees can use powerful support tools, and log all their actions.
- Train employees to verify unknown 'IT' callers using a separate, known channel.

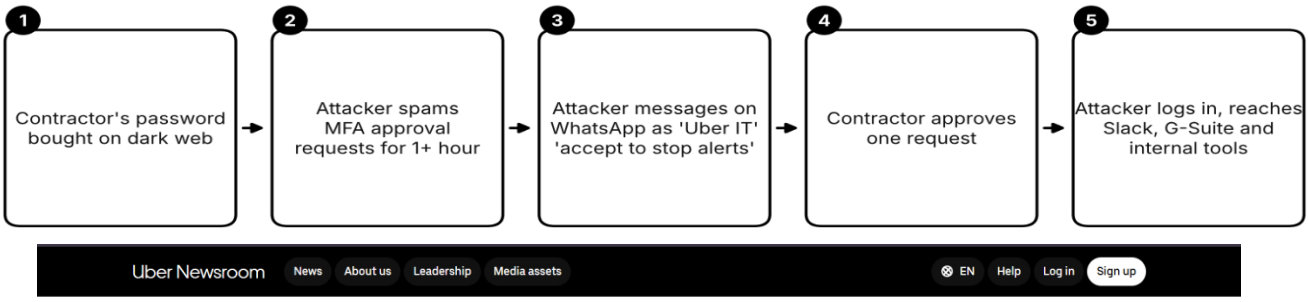
Case 4: Uber (2022)

❖ Overview :-

Company	Uber Technologies
When	15 September 2022
Attacker	Uber linked the attacker to the Lapsus$ group; the attacker is widely reported to be a teenager
Attack type	MFA fatigue (repeated login approval requests) combined with fake IT support

❖ History :-

Uber said the attacker took over the account of an external contractor. The contractor's personal device had probably been infected with malware and the corporate password was likely bought on the dark web. Because the account used two-factor authentication, the attacker kept trying to log in so the contractor received approval requests again and again. The attacker also messaged the contractor on WhatsApp pretending to be Uber IT and said the requests would stop if one was accepted. The contractor accepted one, and the attacker logged in. From there the attacker reached other employee accounts and tools such as Slack and G-Suite, and even posted a message in Uber's company-wide Slack channel.



September 16, 2022

Security update

Uber Team

Share this article

September 19, 10:45am PT

While our investigation is still ongoing, we are providing an update on our response to last week's security incident.

What happened?

An Uber EXT contractor had their account compromised by an attacker. It is likely that the attacker purchased the contractor's Uber corporate password on the dark web, after the contractor's personal device had been infected with malware, exposing those credentials. The attacker then repeatedly tried

❖ **Loss :-**

- Uber did not publish a financial loss figure.
- The attacker downloaded some internal Slack messages, information from an internal finance tool and had access to Uber's HackerOne bug-report dashboard.
- Uber said it saw no evidence that sensitive customer data, such as card numbers or trip history, was accessed, and its public services kept running.

❖ **Recovery process :-**

Uber blocked or reset the compromised accounts, disabled many internal tools, rotated keys for internal services and locked its codebase so that no new code could be changed. Employees had to log in again to regain access, and Uber added more monitoring. The company informed law enforcement, worked with the FBI and the US Department of Justice, and hired digital forensics firms.

❖ **Solution :-**

- Use number-matching or hardware-key MFA instead of simple 'approve' buttons.
- Raise an alert when a user receives many MFA requests in a short time.
- Make contractors use company-managed devices and limit what they can reach.
- Teach staff to never approve a prompt they did not start, and to report it at once.

Case 5: MGM Resorts (2023)

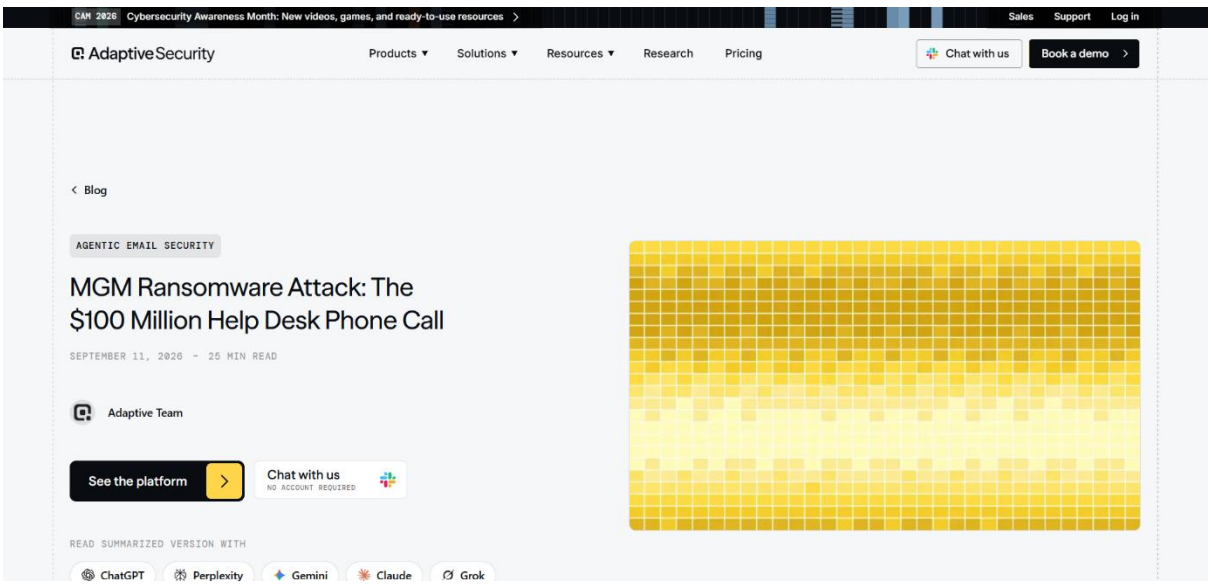
❖ Overview :-

Company	MGM Resorts International, a large casino and hotel company
When	Disclosed on 10 September 2023; disruption lasted about 10 days
Attacker	Scattered Spider (also called Octo Tempest), working with the ALPHV ransomware group, according to reports
Attack type	Voice phishing of the IT help desk, followed by ransomware

❖ History :-

The group claimed that it found an MGM employee on LinkedIn and phoned the company's IT help desk pretending to be that person, and the help desk gave access. MGM has not confirmed this in its filings, but the US agencies CISA and the FBI reported in November 2023 that Scattered Spider impersonates employees over the phone to trick help desks. After getting in, the attackers moved through the network and used ransomware. MGM shut down many systems to limit the damage, which affected slot machines, hotel room keys, reservations and websites at its properties.





❖ Loss :-

- MGM estimated an impact of about $100 million on its September earnings (Adjusted Property EBITDAR), mainly in Las Vegas and regional properties.
- It also reported less than $10 million of one-time costs in the third quarter for consultants, lawyers and advisers.
- Personal data of some customers who dealt with MGM before March 2019 was taken, including names, contact details, dates of birth and driver's licence numbers; a limited number also lost Social Security or passport numbers. MGM said bank account and card details were not taken.

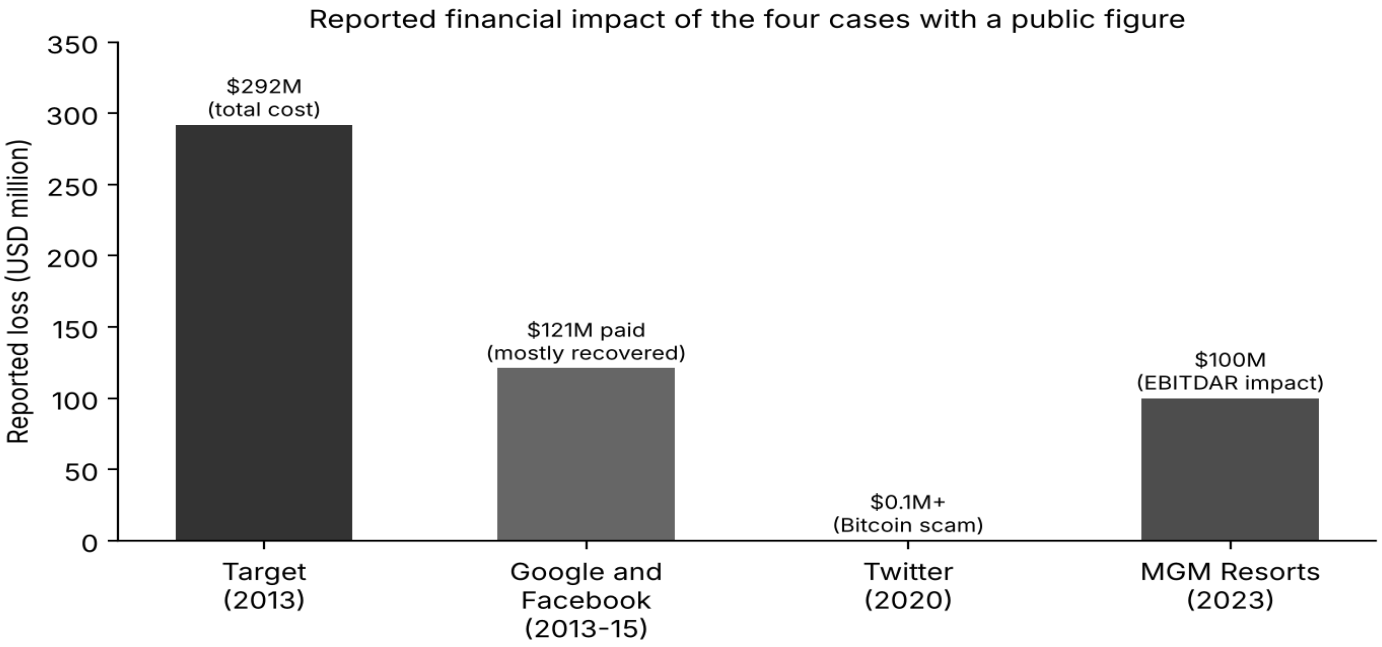
❖ Recovery process :-

MGM shut down affected systems and then restored them step by step, and domestic properties returned to normal operations. It set up a help line and a web page, sent notices to affected people and offered free identity protection and credit monitoring. The company worked with outside security experts to strengthen its systems and said its cyber insurance should cover the disruption and expenses.

❖ Solution :-

- Verify identity strictly before resetting a password or MFA device, for example by a call-back or manager approval.
- Apply extra checks to privileged and administrator accounts.
- Train help-desk staff on phone-based social engineering.
- Keep offline backups and a tested plan to run key services manually during an outage.

➢ Comparison


Reported financial impact of the four cases with a public figure
Reported loss (USD million)
350
300
250
200
150
100
50
0
$292M
(total cost)
$121M paid
(mostly recovered)
$0.1M+
(Bitcoin scam)
$100M
(EBITDAR impact)
Target
(2013)
Google and
Facebook
(2013-15)
Twitter
(2020)
MGM Resorts
(2023)